



German International University (GIU)

Faculty of Informatics and Computer Science

Business Continuity and Risk Management

Project Report: Milestone 1 & Milestone 2

Selected System: Security Monitoring / SIEM Platform

Group Members:

Eiad Hamdy - 13006650

Loay Waleed - 13005962

Omar Samer - 13006987

Marwan Ahmed - 13003753

Ali Mohab - 13003995

MILESTONE 1:

Part A: System Description (Context Definition)

Selected System: System F – Security Information and Event Management (SIEM) Platform

1. System purpose

The selected system for this project is a Security Information and Event Management (SIEM) platform, which represents a critical component of modern organizational cybersecurity infrastructure.

A SIEM system is designed to collect, aggregate, analyze, and correlate security-related data from multiple sources across an organization's IT environment in real time. Its primary purpose is to detect potential security incidents, support incident response activities, and ensure continuous monitoring of the organization's digital assets.

In a typical enterprise environment, the SIEM platform acts as a centralized intelligence hub, enabling security teams to identify suspicious patterns, anomalies, and potential threats that may not be visible when analyzing individual systems separately.

From a business continuity perspective, the SIEM system plays a proactive and reactive role:

- Proactively, it helps detect threats before they escalate into major incidents.
- Reactively, it provides critical forensic data required for incident investigation and recovery.

Without a SIEM system, organizations would lack visibility into ongoing security events, significantly increasing the risk of undetected breaches, prolonged downtime, and severe operational disruptions.

2. Main Functions of the SIEM System

The SIEM platform performs several essential functions that support both cybersecurity and business operations:

Log Collection and Aggregation

The system collects logs from a wide range of sources, including:

- Network devices (routers, firewalls)
- Servers and operating systems
- Applications and databases
- Endpoint devices

These logs are centralized to allow unified monitoring and analysis.

Event Correlation and Analysis

SIEM systems analyze collected data using predefined rules, signatures, and behavioral analytics to:

- Identify abnormal activities
- Correlate events across multiple systems
- Detect complex attack patterns (e.g., multi-stage attacks)

This function is critical in identifying advanced threats such as lateral movement or privilege escalation.

Real-Time Threat Detection

The system continuously monitors incoming data streams and generates alerts when suspicious activity is detected, such as:

- Unauthorized access attempts
- Malware execution
- Data exfiltration behavior

Real-time detection significantly reduces the time between attack occurrence and response.

Alerting and Notification

When a potential security incident is detected, the SIEM system:

- Generates alerts with severity levels
- Notifies security analysts or incident response teams
- Escalates critical threats based on predefined thresholds

3. Users and Stakeholders

The SIEM system involves multiple stakeholders across technical and business domains:

Security Operations Center (SOC) Analysts

- Monitor alerts and investigate incidents
- Use SIEM dashboards daily
- First line of defense against cyber threats

Incident Response Team (IRT)

- Handles confirmed security incidents
- Uses SIEM data for containment and recovery
- Relies heavily on accurate event correlation

IT Operations Team

- Maintains infrastructure and system availability
- Integrates systems with SIEM
- Supports log sources and system configurations

Management and Executives

- Use SIEM-generated reports for decision-making
- Assess organizational risk posture
- Ensure compliance with regulations

4. Types of Data Processed

The SIEM system processes large volumes of sensitive and critical data, including:

Log Data

- System logs (OS-level events)
- Network logs (traffic, firewall activity)
- Application logs

Security Events

- Authentication attempts (successful/failed logins)
- Intrusion detection alerts
- Malware activity

User Activity Data

- User access patterns
- Privileged account usage
- Behavioral activity tracking

5. Business Processes Dependent on the SIEM System

The SIEM platform is deeply integrated into several critical business processes

Continuous Security Monitoring

Organizations rely on SIEM systems to maintain 24/7 visibility over their infrastructure. Without it, threats may remain undetected for extended periods.

Incident Detection and Response

The SIEM system is the primary detection engine for security incidents.
If it fails:

- Incidents may go unnoticed
- Response time increases significantly

Threat Intelligence and Risk Management

SIEM systems support:

- Risk analysis
- Threat trend identification
- Strategic security planning

Business Decision-Making

Executives rely on SIEM insights to:

- Understand risk exposure
- Allocate security budgets
- Make strategic decisions

Part B: Applying Information Security Risk Management

1. Selected Risk Management Framework

The NIST SP 800-30 – Guide for Conducting Risk Assessments has been selected as the primary risk management framework.

2. Justification for Selecting NIST SP 800-30

The selection of the NIST SP 800-30 framework is based on several technical and practical considerations that make it highly suitable for analyzing risks in a SIEM (Security Information and Event Management) system.

Firstly, NIST SP 800-30 provides a structured and systematic methodology for identifying, analyzing, and evaluating risks. Unlike generic approaches, it defines clear steps such as:

- Threat identification
- Vulnerability identification
- Likelihood determination
- Impact analysis

This aligns directly with the requirements of the project, which explicitly demands a formal and named framework rather than general risk discussion.

Secondly, NIST is widely adopted in cybersecurity operations and security monitoring systems, making it highly relevant for SIEM platforms. Since SIEM systems are directly involved in detecting and responding to threats, using a framework that is deeply integrated with cybersecurity practices ensures realistic and applicable results. Therefore, the NIST framework is selected as it provides a comprehensive, practical, and industry-relevant approach for analyzing risks affecting the SIEM system.

3. Risk Register

Asset	Threat	Vulnerability	Likelihood	Impact	Risk Score	Risk Level	Treatment
SIEM Platform	DDoS Attack	No load balancing / redundancy	4	5	20	High	Mitigation
Log Data Repository	Data Tampering	Lack of integrity controls	3	5	15	High	Mitigation
SIEM Database	Unauthorized Access	Weak authentication	4	5	20	High	Mitigation
Correlation Engine	Misconfiguration	Poor rule management	3	4	12	Medium	Mitigation

Asset	Threat	Vulnerability	Likelihood	Impact	Risk Score	Risk Level	Treatment
Network Infrastructure	Network Failure	Single point of failure	3	5	15	High	Mitigation
SIEM System	Insider Threat	Excessive user privileges	3	5	15	High	Mitigation
Log Collection System	Log Loss	No backup mechanism	3	4	12	Medium	Mitigation
SIEM Server	Hardware Failure	No failover system	2	5	10	Medium	Mitigation
User Credentials	Credential Theft	Weak password policies	4	4	16	High	Mitigation
Compliance Logs	Data Leakage	Lack of encryption	3	5	15	High	Mitigation

4. Risk Analysis Summary

From the risk register, it is evident that:

- The majority of risks fall under the High category, indicating that the SIEM system operates in a high-risk environment.
- The most critical risks are related to:
 - System availability (DDoS, hardware failure)
 - Data integrity (log tampering)
 - Unauthorized access

This highlights that the SIEM system is both:

- A high-value target
- A critical dependency for security operations

Part C: Business Impact Analysis (BIA)

1. Weight Analysis Table

To determine the criticality of the SIEM system, a weighted analysis is conducted using four key criteria:

- Revenue Dependency
- Customer Impact
- Regulatory Exposure
- Operational Dependency

SIEM System Scoring

Each criterion is scored from **1 (Low)** to **5 (Very High)**:

Criteria	Weight Score Weighted Score		
Revenue Dependency	0.30	4	1.20
Customer Impact	0.25	4	1.00
Regulatory Exposure	0.20	5	1.00
Operational Dependency	0.25	5	1.25
Total Score	1.00	—	4.45 / 5

Criticality Interpretation

The SIEM system achieved a score of 4.45 out of 5, which indicates that:

- The system is highly critical
- It must be prioritized for recovery during disruptions
- Any downtime will have serious operational and security consequences

4. Recovery Objectives

Recovery Time Objective (RTO).

Defined Value: 2 Hours

Justification:

- SIEM systems are essential for real-time monitoring
- Delays beyond 2 hours create a security visibility gap
- Attackers can exploit this window

Recovery Point Objective (RPO)

Defined Value: 15 Minutes

Justification:

- SIEM relies on continuous log ingestion
- Losing more than 15 minutes of logs may:
 - Hide attack traces
 - Prevent accurate forensic analysis

Work Recovery Time (WRT)

Defined Value: 1 Hour

Justification:

- Includes:
 - Log synchronization
 - Rule validation
 - System testing
- SIEM systems require verification before becoming fully operational

Maximum Tolerable Downtime (MTD)

Defined Value: 4 Hours

Justification:

- Beyond 4 hours:
 - Security monitoring is effectively blind
 - Risk of undetected breaches increases significantly
 - Business operations become unsafe

MILESTONE 2:

Part A: Continuity & Backup Strategy

1. Continuity Strategy Overview

The continuity strategy for the SIEM system is designed to ensure that security monitoring and incident detection remain operational even during system failures or cyber incidents.

Unlike typical systems, SIEM platforms are mission-critical, meaning that downtime directly results in:

- Loss of threat visibility
- Increased risk of undetected attacks
- Delayed incident response

Therefore, the strategy focuses on:

- High availability
- Data redundancy
- Fast recovery
- Minimal data loss

2. Backup Strategy

Selected Backup Types

A hybrid backup strategy is implemented combining:

Full Backup (Weekly)

- Complete backup of:
 - Logs
 - SIEM configurations
 - Correlation rules
- Stored securely in offsite/cloud storage

Incremental Backup (Every 15 Minutes)

- Captures only changes since last backup
- Ensures alignment with RPO = 15 minutes

3. Storage & Redundancy (RAID Selection)

Selected RAID Level: RAID 10

Why did we choose RAID 10?

RAID 10 (1+0) combines:

- Mirroring (RAID 1): data redundancy
- Striping (RAID 0): high performance
- RAID 5: slower write performance (bad for SIEM logs)
- RAID 6: high redundancy but slower
- RAID 1: safe but not scalable

4. High Availability Strategy

Failover Mechanism

A failover architecture is implemented:

- Primary SIEM server (active)
- Secondary SIEM server (standby)

If failure occurs:

System automatically switches to backup server

Clustering

Multiple SIEM nodes are deployed in a clustered architecture:

- Load distributed across nodes
- Prevents overload
- Ensures system continues even if one node fails

Cloud Backup Integration

- Logs replicated to cloud storage (e.g., AWS / Azure)
- Enables:
 - Disaster recovery
 - Offsite data protection

5. Workarounds (Business Continuity During Failure)

If SIEM system is unavailable, temporary workarounds are used:

Manual Log Monitoring

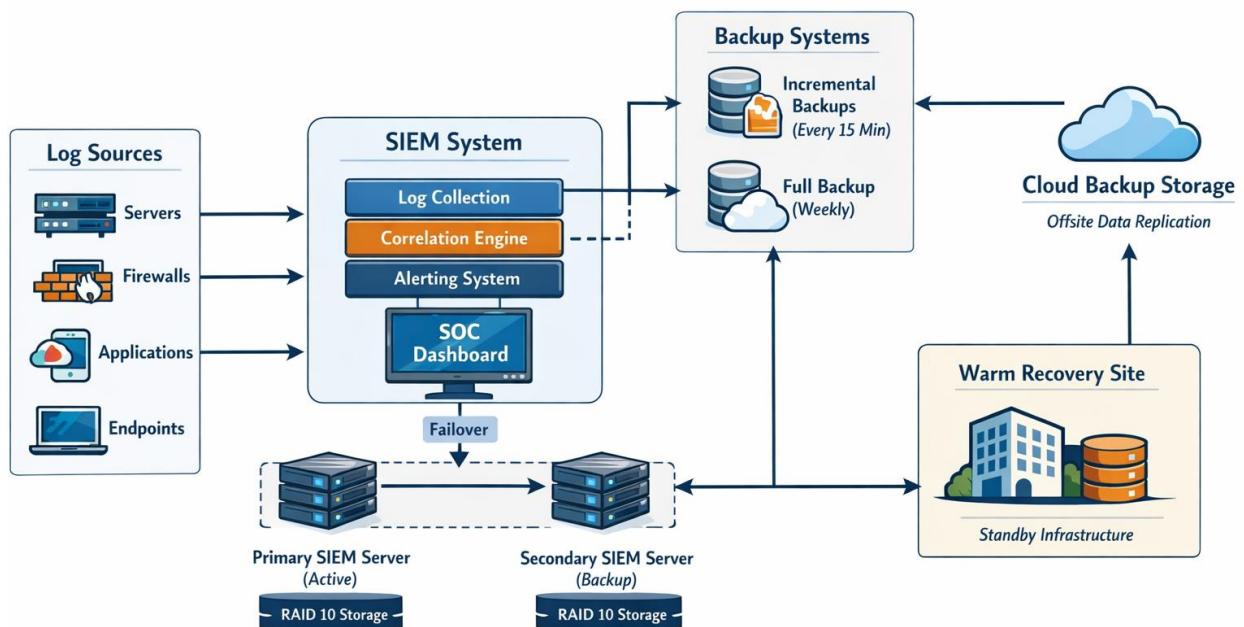
- Logs accessed directly from:
 - Servers
 - Firewalls
- Security team manually inspects logs

Network Monitoring Tools

- Firewalls and IDS operate independently

Part B: Architecture Design

SIEM Continuity Architecture



The diagram presents the SIEM system architecture designed to ensure continuous operation and fast recovery during failures. It shows how logs from various sources such as servers, firewalls, applications, and endpoints are collected and processed by the SIEM system to generate alerts for security monitoring. The design includes a backup mechanism with frequent incremental backups and periodic full backups, along with cloud storage for offsite protection. It also illustrates a failover setup with primary and secondary servers supported by RAID 10 storage, ensuring high availability. In case of major disruptions, a warm recovery site is used to restore operations, allowing the system to meet its recovery time and data loss requirements.